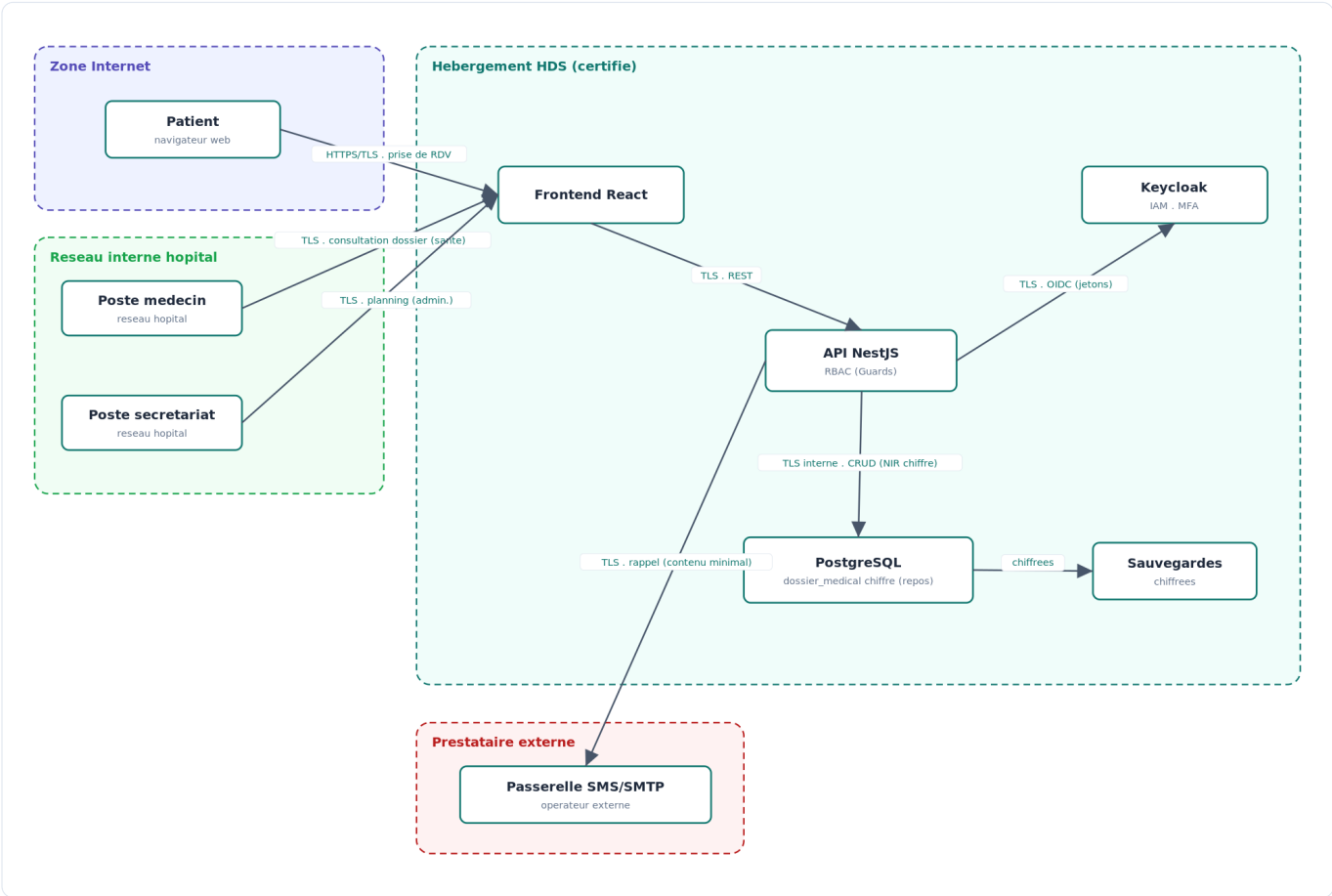


# Cartographie des flux de données de santé

MediPlan — flux, stockage, habilitations et mesures de chiffrement · 07/07/2026

Cette cartographie recense les **flux de données de santé** dans MediPlan : par quels composants elles transitent, où elles sont **stockées**, **qui y a accès** (matrice d'habilitation) et les **mesures de chiffrement** en transit et au repos. Elle prolonge l'analyse EBIOS (R1 fuite en transit/repos, R2 accès illégitime) et la preuve apportée par le POC (chiffrement au repos + RBAC).

## 1. Schéma des flux et zones de confiance



Trois zones de confiance : **Internet** (patient), **réseau interne de l'hôpital** (postes soignants) et **hébergement HDS certifié** (frontend, API, Keycloak, PostgreSQL, sauvegardes). Le prestataire de notification est externe et ne reçoit qu'un rappel à contenu minimal. Chaque flux traversant une frontière de zone est protégé par TLS.

## 2. Où sont stockées les données

| Emplacement                                   | Données                                       | Protection au repos                                                               |
|-----------------------------------------------|-----------------------------------------------|-----------------------------------------------------------------------------------|
| PostgreSQL — table dossier_medical (zone HDS) | NIR, antécédents, groupe sanguin              | NIR chiffré applicativement (AES-256-GCM, clé hors base) + chiffrement disque HDS |
| PostgreSQL — autres tables (zone HDS)         | Identité, coordonnées, RDV, créneaux, comptes | Chiffrement disque HDS ; cloisonnement des accès                                  |
| Sauvegardes (zone HDS)                        | Copie de la base                              | Sauvegardes chiffrées (règle 3-2-1)                                               |
| Journaux d'accès — journal_acces (zone HDS)   | Traces d'accès aux données                    | Écriture seule, conservation encadrée                                             |

### 3. Matrice d'habilitation (qui accède à quoi)

| Ressource / donnée                          | Patient | Médecin | Secrétariat | Admin | Prestataire notif. |
|---------------------------------------------|---------|---------|-------------|-------|--------------------|
| Données administratives (identité, contact) | L+E*    | L       | L+E         | —     | —                  |
| Dossier médical (NIR, antécédents)          | —       | L+E     | —           | —     | —                  |
| Planning / créneaux                         | L       | L+E     | L+E         | —     | —                  |
| Rendez-vous                                 | L+E*    | L       | L+E         | —     | —                  |
| Comptes utilisateurs                        | —       | —       | —           | L+E   | —                  |
| Journaux d'accès                            | —       | —       | —           | L     | —                  |

L = lecture · E = écriture · L+E = lecture/écriture · — = aucun accès · \* = uniquement ses propres données. Le prestataire de notification ne reçoit qu'un message de rappel à contenu minimal (aucun accès à la base). Cette matrice matérialise le RBAC démontré par le POC (seul le médecin accède au dossier médical).

### 4. Mesures de chiffrement préconisées

#### En transit

| Flux                                              | Mesure                                                             |
|---------------------------------------------------|--------------------------------------------------------------------|
| Patient ↔ Frontend / API                          | HTTPS / <b>TLS 1.3</b>                                             |
| Postes internes (médecin, secrétariat) ↔ Frontend | TLS 1.3                                                            |
| Frontend ↔ API NestJS                             | TLS (REST)                                                         |
| API ↔ Keycloak                                    | TLS (OIDC, jetons)                                                 |
| API ↔ PostgreSQL                                  | TLS interne (connexion chiffrée)                                   |
| API ↔ Passerelle SMS/SMTP                         | TLS + <b>contenu minimal</b> (aucun détail médical dans le rappel) |

#### Au repos

| Donnée / support      | Mesure                                                                                    |
|-----------------------|-------------------------------------------------------------------------------------------|
| NIR (dossier_medical) | <b>Chiffrement applicatif AES-256-GCM</b> , clé conservée hors base (démontré par le POC) |
| Base PostgreSQL       | Chiffrement disque de l'hébergeur HDS                                                     |
| Sauvegardes           | Sauvegardes chiffrées (règle 3-2-1)                                                       |

Lien EBIOS : le chiffrement **en transit** et **au repos** traite le risque critique **R1** (fuite de données de santé) ; la matrice d'habilitation et l'authentification forte traitent **R2** (compromission de compte). La mesure au repos la plus structurante — chiffrement du NIR avec clé hors base — a sa faisabilité prouvée par le POC.